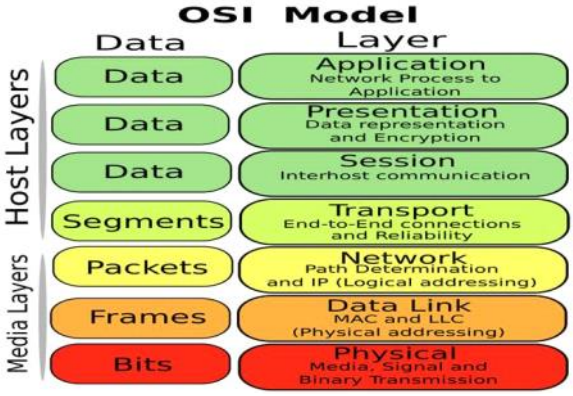
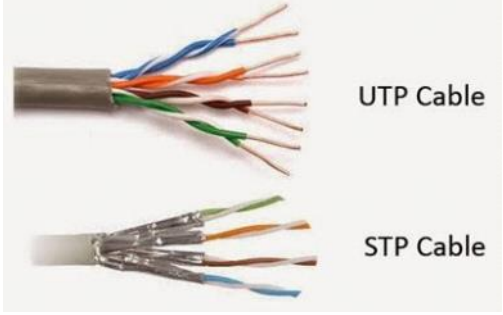
Domain 4: Communication and Network Security

- **Implement secure design principles in network architectures**
  - Data transmission is the physical transfer of data over a communication channel, Network data transmission components include communication protocols, connectivity devices, and transmission media
  - Layering Models
    - The OSI Reference Model
    - The TCP/IP Model
  - The OSI Reference Model (Design with an objective how Destination receives data)
    - The Open Systems Interconnection (OSI) reference model is structured into seven layers



  - **Physical Layer**
    - Physical Topologies are defined at this layer - Cable, Wireless, and Fiber
    - At the physical layer, bits are encoded and decoded through transmitting and receiving devices and media. Media and device types may potentially utilize signals that include light, radio, or electrical.
    - Choice of Network Media
      - **Throughput** - The rate that data will be transmitted. Certain Cables such as Fiber optic are designed for hauling an incredible amount of data at once.
      - **Distance between Devices** - Degradation or loss of a signal in long runs of cable is a perennial problem, especially if the signal is at high frequency.
      - **Data Sensitivity** - What is the risk of someone intercepting the data in the cables?
      - **Environment** - Cables may have to be bent when installing, Which contributes to the degradation of conduction and signal distortion.
    - Media
      - Twisted Pair
        - Pairs of copper wires are twisted together to reduce electromagnetic interference and cross talk
        - Unshielded Twisted Pair (UTP)
          - UTP is more susceptible to interference from external electrical sources as with crosstalk or noise
          - Protection against surveillance more difficult when using UTP than with shielded wire.
          - UTP may not be a desirable choice when transmitting very sensitive data or when installed in an environment with much electromagnetic interference (EMI) or radio frequency interference (RFI).
          - Despite its drawbacks, UTP is the most common cable type
          - UTP is inexpensive
        - Shielded Twisted Pair (STP)
          - Pairs of insulated twisted copper are enclosed in a protective (metal foil) jacket or shield. STP uses an electronically grou nded shield to protect the signal.
          - The shield protects the electronic signals from outside.
          - STP is more expensive and is bulkier and hard to bend during installation



      - Fiber-Optics (Fastest way to send data)

- Fiber optics use **light pulses to transmit information** within fiber lines instead of using electronic pulses to transmit information down copper lines.
- Uses Optical form
- Transmit over a Glass or Plastic Medium
- **Mostly Immune to interference like EMI or RFI (Which Media is Immune for EMI/RFI)**
- Three types of fiber optic cable
  - Single-mode:
    - This mode has a small diameter core that decreases the number of light reflections within the cable. This allows for great transmission distance, up to 80Km, 50 times further than multimode.
  - Multimode:
    - This mode uses a larger diameter cable than single-mode. Light reflections subsequently increase. Typically used for short distances. Transmission distances are up to 400m.
  - Plastic optical fiber (POF):
    - This uses a plastic core and allows for larger diameter fiber cores.
    - Distortion of the signal is greatly increased using plastic, which limits its range significantly Transmission distances are around 100m.
- Fiber optic cable provides most protection against EMI/RFI and the highest bandwidth
- Fiber Optic taps can disclose the data
- Used end to end encryption when required = Control

▪ Coaxial Cable
- **Which Media is immune to EMI with Strong Shield Coaxial Cable**
- Instead of a pair of wires twisted together, a coaxial cable (or simply, coax) uses one thick conductor that is surrounded by a grounding braid of wire.
- **The superior insulation protects the coaxial cable from electronic interference, such as EMI and RFI.**
- The cable is expensive and difficult to bend during installation

▪ Repeaters, hubs, cables, USB, DSL, ISDN, ATM
▪ Physical topologies: BUS, MESH, STAR, TREE, RING

○ **Data-Link Layer**
- The data-link layer prepares the packet that it receives from the network layer to be transmitted as frames on the network. This layer ensures that the information that it exchanges with its **peers is error-free.**
- **There are two sublayers within the data-link layer:**
  ▪ Logical Link Control (LLC) Layer - This layer is concerned with sending frames to the next link on a local area network.
  ▪ Media Access Control (MAC) Layer
- Will unstructured the date and send.

- Bridge
  ▪ Bridge is a device to connect 2 different topologies on Layer 2
  ▪ A Basic bridge filters out frames that are not destined for another segment.
    - Can connect similar or dissimilar (translational) network architecture
    - Connects LANs with unlike media types
    - Filter traffic between segments based on Media Access Control (MAC) Addresses
- Switches
  ▪ The core device used to build LANs
    - Establishes a collision domain per port
    - Provide a more efficient transmission using CSMA/CD logic within Ethernet
    - **Switches are multi-port bridges and are used to break up collision domains**
  ▪ Security features - Port Blocking, Port Authentication, MAC Filtering, VLANs
- VlAN
  ▪ Virtual local area networks (VLANs) allow network administrators to use switches to create software-based LAN segments that can be defined based on factors other than a physical location.
  ▪ VLAN, which reduces congestion due to broadcasts.
  ▪ It is important to remember that VLANs do not guarantee a network's security
  ▪ VLAN can be created so that engineers can efficiently share confidential documents, but the VLAN does not significantly protect the documents from unauthorized access.
- Protocols
  ▪ L2F, PPTP, L2TP, PPP, SLIP, ARP, RARP, SLARP, IARP, SNAP, BAP, CHAP, LCP, LZS, MLP, Frame Relay, Annex A, Annex D, HDLC, BPDU, LAPD, ISL, MAC, Ethernet, Token Ring, FDDI
  ▪ Token Passing
    - FDDI
      - High-Speed token-based network communication.
      - FDDI (Fiber Distributed Data Interface) is a set of ANSI and ISO standards for data transmission on fiber -optic lines in a local area network (LAN) that can extend in range up to 200 km (124 miles).
      - The FDDI protocol is based on the token ring protocol. It offers a speed of 100Mbps.
    - Token Ring
      - Requires a TOKEN to Communicate over the network
  ▪ **HDLC (High-Level Data Link Control) and SDLC (Synchronous Data Link Control)** are two protocols that provide a point to the multipoint

interconnection between computers. The main difference between HDLC and SDLC is actually their origin.

- **RARP, Reverse address resolution protocol** - When a hardware address is known but the IP address has to be found. (like a diskless machine)
- Lan Technologies
  - Wired
    - Carrier Sense Multiple Access with Collision Detection (CSMA/CD):
      - Devices on a LAN CSMA/CD listen for a carrier before transmitting data. If another transmission is not detected, the data will be transmitted. It is possible that a station will transmit before another station's transmission had enough time to propagate.
      - Ethernet IEEE 802.3.
      - Token Ring IEEE 802.5
  - Wireless
    - Carrier Sense Multiple Access with Collision Avoidance (CSMA/CA):
      - Avoids collisions by sensing if the media is clear for transmission.
      - If the media is clear for transmission, **then the potential transmitter sends out a special control frame called a Request to Send (RTS). The RTS is sent to the common access point along with all stations on that segment. If the RTS is accepted by the access point, then a Clear to Send (CTS) is sent back to the potential transmitter and all stations connected to the access point**. In this way, collisions do not have an opportunity to take place.
      - CSMA/CA is used in the IEEE 802.11 wireless standard.

- **Network Layer**
  - **Packet Filtering Firewall Operates Network Layer**
  - **Stateful Inspection**
    - Usually Operates at the network layer of the OSI Model
  - Common OSL Layer 3 Threats -- Ping of Death
  - The network layer moves data between networks as packets utilizing logical addressing schemes.
  - Data-link layer relies on hardware addressing, the network layer uses logical addressing that is created when a host is configured
  - Routing Protocols
    - Message routing, error detection, and control of node data are managed.
    - IP, IPSEC, ICMP, BGP, OSPF, RIP, BOOTP, DHCP, ZIP, DDP, X.25, NAT and IGMP
  - Devices
    - Routers
      - Routers route packets to other networks. Most commonly used to connect LANs to WANs.
    - Firewall
      - Security
    - Types for Networks
      - Intranet - Outside Untrusted network
      - Intranet - Internal Network
      - Extranet - Outside Semi-Trusted
  - Protocols
    - Internet Protocol (IPV4)Networking (32 bits long)
      - The Internet Protocol (IP) is the dominant protocol that operates at the OSI Network Layer 3.
      - IP is responsible for addressing packets so that they can be transmitted from the source to the destination hosts.
      - A connectionless protocol that does not guarantee error-free delivery.
      - Packet form & Fragmentation happens on Layer 3.
      - **Addressing** – IP uses the destination IP to transmit packets thru networks until delivered
      - **Fragmentation** – IP will subdivide a packet if its size is greater than the maximum allowed on a local network.
    - Internet Protocol (IPV6) Networking
      - IPv6 is a modernization of IPv4
        - A much larger address field: IPv6 addresses are 128 bits, which supports 2128 hosts. Suffice it to say that we will not run out of addresses.
        - Improved security: IPSec can be implemented in IPv6. This will help ensure the integrity and confidentiality of IP packets and allow communicating partners to authenticate with each other.
        - Improved quality of service (QoS): This will help services obtain an appropriate share of a network's bandwidth.
    - Internet Control Message Protocol (ICMP)
      - The ICMP is used for the exchange of control messages between hosts and gateways and is used for diagnostic tools such as ping and traceroute.
      - ICMP can be leveraged for malicious behavior, including man-in-the-middle and denial-of-service attacks.
    - Internet Group Management Protocol (IGMP)
      - IGMP is used to manage multicasting groups that are a set of hosts anywhere on a network that is listening for a transmission .
      - Multicast agents administer multicast groups, and hosts send IGMP messages to local agents to join and leave groups.
    - SKIP, Simple Key Management for Internet Protocols
      - provides high availability in encrypted sessions to protect against crashes. Exchanges keys on a session-by-session basis.
    - ARP, Address resolution protocol
      - Used to match an IP address to a hardware MAC address. ARP sends out a broadcast to a network node to reply with its hardware address. It stores the address in a dynamic table for the duration of the session, so ARP requests are only sent the first time
    - BootP, Bootstrap Protocol
      - when a wireless workstation is on-lined it sends out a BootP request with its MAC address to get an IP address and the file from which

it should boot. Replaced by DHCP

- BGP provides much of the backbone for the internet's routing.
- RIP is an early protocol that is still occasionally used.
- OSPF is a fast, scalable protocol used in large enterprise networks.

- Ip Address Class

Class	Range of Number of Octets for First Octet Network Number		Number of Hosts in Network
A	1–126	1	16,777,214
B	128–191	2	65,534
C	192–223	3	254
D	224–239	Multicast	
E	240–255	Reserved	

Class	Address range	Supports
Class A	1.0.0.1 to 126.255.255.254	Supports 16 million hosts on each of 127 networks.
Class B	128.1.0.1 to 191.255.255.254	Supports 65,000 hosts on each of 16,000 networks.
Class C	192.0.1.1 to 223.255.254.254	Supports 254 hosts on each of 2 million networks.
Class D	224.0.0.0 to 239.255.255.255	Reserved for multicast groups.
Class E	240.0.0.0 to 254.255.255.254	Reserved for future use, or research and development purposes.

- **Transport Layer**
  - The transport layer delivers end-to-end services through segments transmitted in a stream of data and controls streams of data to relieve congestion through elements that include quality of service (QoS).
  - Transmission Control Protocol (TCP)
    - The Transmission Control Protocol (TCP) provides connection-oriented data management and reliable data transfer.
  - User Datagram Protocol (UDP)
    - The UDP provides connectionless data transfer without error detection and correction.
    - UDP similarly uses port numbers to TCP.
    - As a connectionless protocol, UDP is useful for attacks as there is no state for routers or firewalls to observe and monitor.
  - TCP and User Datagram Protocol (UDP)Ports
    - TCP and User Datagram Protocol (UDP) map data types using port numbers associated with services.
    - **Well-Known Ports: Ports 0–1023**
      - These ports are related to the common protocols that are utilized in the underlying management of Transport Control Protocol/ Internet Protocol (TCP/IP) system (Domain Name Service (DNS), Simple Mail Transfer Protocol (SMTP), etc.)
    - **Registered Ports: Ports 1024–49151**
      - These ports typically accompany non-system applications associated with vendors and developers.
    - **Dynamic or Private Ports or Ephermal: Ports 49152–65535**
      - Whenever a service is requested that is associated with Well-Known or Registered Ports those services will respond with a dynamic port.
  - Port knocking - In computer networking, port knocking is a method of externally opening ports on a firewall by generating a connection attempt on a set of prespecified closed ports.

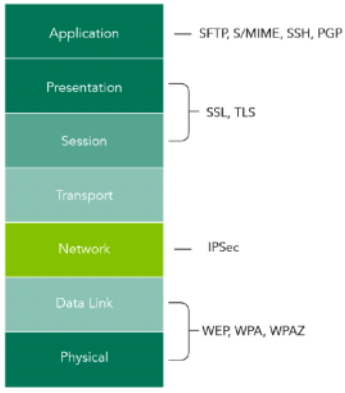
- **Session Layer**
  - **Circuit-level proxy firewall**
    - Operates at the Session Layer of the OSI Model and makes access decisions based on address, port and protocol type, and not on the packet content.
  - The session layer provides a logical persistent connection between peer hosts. The session layer is responsible for creating, maintaining, and tearing down the session.
  - Session layer protocols include the following:
    - PAP – password authentication protocol
    - PPTP – Point-to-Point Tunneling Protocol
    - RPC – remote procedure call protocol
- **Presentation Layer**
  - The presentation layer maintains that communications delivered between sending and receiving computer systems are in a common and discernable system format.
  - Does Encoding, Conversion and Compression Services, Translation Services
- **Application Layer**
  - The application layer supports or hosts the function of applications that run on a system. All manner of a human supported interfaces,

messaging, systems control, and processing occurs at the application level. While the application layer itself is not the application it is where applications run.

- Layer 7 Protocols
  - **Application-level proxy firewall**
    - Operates at the Application Layer of the OSI Model and makes access decisions based on the packet content – the payload.
  - **Kernel proxy**
    - Operates at the Application Layer and is considered as 5th Generation firewalls.
  - DHCP/DHCPv6 - Dynamic Host Configuration Protocol/v6, **Port No 67,68**
    - DHCP is a client/server application that is designed to assign IP addresses from a pool of pre-allotted addresses on a DHCP server.
  - DNS - Domain Name System **Port No 53**
    - DNS resolves Fully Qualified Domain Names (FQDN) to IP addresses and transmits data on port 53.
  - HTTP - Hypertext Transfer Protocol - **Port No 80**
    - Designed to transfer HTML web pages between a server and a client, traffic is sent in clear text but can be encrypted.
    - Encrypted using SSL or TLS.
    - HTTP is a stateless protocol.
  - LDAP - Lightweight Directory Access Protocol (works on the concept of X.500) **Port No 389**
  - SMTP - Simple Mail Transfer Protocol **Port No 25**
  - SNMP - Simple Network Management Protocol, **Port No 161**
    - Internet Standard protocol for collecting and organizing information about managed devices on IP networks and for modifying t hat information to change device behavior
  - DNS Security Extensions (DNSSEC), Network basic input-output system (NetBIOS) workgroup environment, Network Information Service (NIS/NIS+) developed by SUN,
  - DNSSEC primary used for DNS Spoofing and DNS Poisoning., HTTP is a stateless protocol
  - FTP is a stateful protocol that allows files to be transmitted between hosts and servers. **Port No 21**
  - FTPS -> FTP over SSL used dynamic ports
  - SFTP -> Secure File Transport Protocol SSH over FTP, SFTP is more like a packet encapsulation, we are encapsulating the packet into SSH tunnel. **Port No 22**
  - TFTP - Trivial File Transport Protocol Trivial File Transfer Protocol (TFTP) is an Internet software utility for transferring files that is simpler to use than the File Transfer Protocol (FTP) but less capable. It is used where user authentication and directory visibility are not required. **UDP Port No 69**

- **Summary**

#	OSI Layer	Description
7	Application Layer	Allows applications to communicate to the other layers
6	Presentation Layer	Prepares and formats data for the application layer
5	Session Layer	Responsible for establishing, maintaining, and terminating communication sessions
4	Transport Layer	Establishes logical connection between devices and provides end-to-end transport services
3	Network Layer	Responsible for adding routing and addressing information to the packet to ensure proper delivery
2	Data Link Layer	Responsible to add hardware source and destination information
1	Physical Layer	Coordinates how protocols use hardware for data transmission and reception



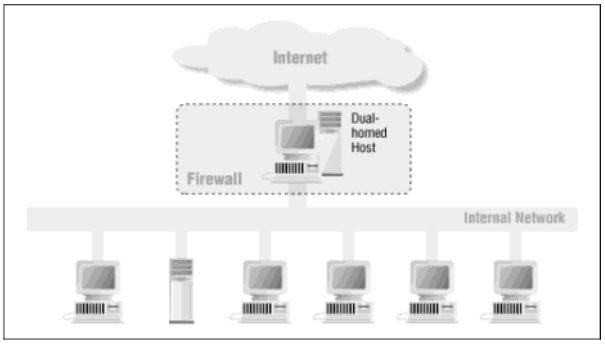
- Zones
  - Security zones are an important part of network deployment,
  - Pivoting - an act of penetrating one network to another network.
  - Network Partitioning: Controlling which traffic is forwarded between segments will go a long way to protecting an organization's critical digital assets from malicious and accidental harm.
  - Network Partitioning
    - Controlling which traffic is forwarded between segments will go a long way to protecting an organization's critical digital assets from

malicious and accidental harm.

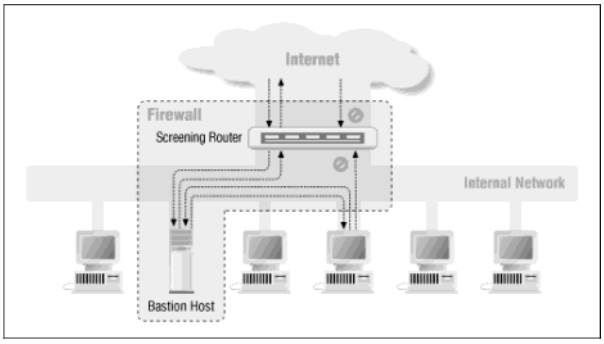
- Trusted Zones: “Private network” which are trusted services provided to an internally protected network.
  - E.g. Windows, Linux, Databases, SIEM, Scanners, IDS/IPS
- Untrusted Zones: “Public networks” are referred to as external or internal facing networks.
  - E.g. External Web servers, SIEM, IDS/IPS
- Demilitarized Zone (DMZ): “Screened subnet” protected by 2 or more firewalls contains low -risk services. = More secure architecture
  - E.g. Web servers, Management, SIEM, IPS/IDS, Mail Server, DNS Server

- **Security Perimeter:**
  - The security perimeter is the first line of protection between trusted and untrusted networks, In general, It includes
    - A Firewall
    - Router that helps filter traffic
    - May include Proxies, IDS/IPS.

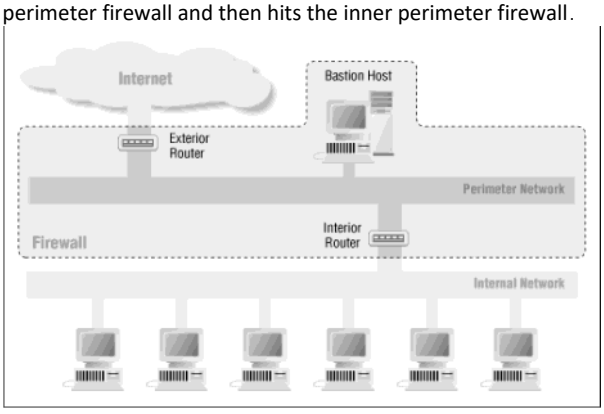
- Firewall Architecture Design
  - Bastion host
    - A Bastion host is a firewall server that is placed between internal and external networks.
    - A bastion host is called a jump system & disables all unnecessary services.
    - Device connecting to the public-facing network exposed to a possibility of being attached.
    - Has a minimalized attack surface.
    - Device usually located within DMZ.
    - Best Practices - Hardened, by patching, disabling of unnecessary services, Change Acc. Pass.
    - Types of bastion host applications include the following:
      - DNS server: Like a phone book for the network, translates from its stored directory of domain names to the resolved IP addres s
      - Email server: A virtual post office, stores inbound email for local distribution and sends out emails externally over SMTP, f or example
      - FTP server: Allows for the transfer of files over the Internet using an established sender and recipient connection, usually password-protected
      - Proxy server: A general application that acts as an intermediary between an endpoint device and another server
      - VPN termination point: An endpoint for a VPN, to extend a private network across a public network
      - Web server: Processes requests via HTTP, for instance, to transmit data across the World Wide Web
    - **Dual-homed firewalls**
      - A computing device/firewall that has more than one interfaces,
        - Typically, there is one interface connected to an untrusted network, and the other connected to a trusted network.
        - Also called a multi-homed
        - A dual-homed host is an appropriate firewall for a situation where:
          - Traffic to the Internet is small.
          - Traffic to the Internet is not business-critical. No services are being provided to Internet-based users.
          - The network being protected does not contain extremely valuable data.



    - **Screened Host**
      - Dual-homed firewall or bastion host
      - **Connected directly to the internal network**
      - Uses an external network router to “screen” traffic before it reaches the firewall
      - Single tiered because there is only one firewall.
      - A screened host architecture is appropriate when:
        - Few connections are coming from the Internet (in particular, it is not an appropriate architecture if the screened host is a public web server). The network being protected has a relatively high level of host security.



- **Screened Subnet**
  - It's a two-tier Architecture similar to a Screened host, instead of screened by a router the first traffic is actually screened by an ou ter perimeter firewall and then hits the inner perimeter firewall.



- Implication of Multi-layer Protocols
  - IP Convergence
    - IP Convergence is the use of the Internet Protocol (IP) as the standard transport for transmitting all information (voice, data, music, video, TV, teleconferencing, and so on).
    - Excellent support for multimedia applications
    - A converged IP network is a single platform on which interoperable devices that run in innovative ways
    - Using a common network protocol to utilize or convert unsupported protocols.
    - Convergence Protocols
      - Fiber Channel Over Ethernet (FCoE)
      - Multiprotocol Label Switching (MPLS)
      - Internet Small Computer System Interface (iSCSI)
      - Voice over IP (VoIP)
      - SCADA
    - **Supervisory Control and Data Acquisition (SCADA)**
      - DNP3 is commonly used in SCADA System (Work on Layer 2 - DNP3)
      - Primary protocols used to communicate between SCADA devices
      - **No Security features**
      - **DNP3**
        - Distributed Network Protocol (DNP3) is a Layer 2 open standards-based communications protocol used between components in a process automation system.
        - DNP3 ensures the reliability of communications within the harsh environments of utilities (error checking).
    - **Fiber Channel Over Ethernet (FCoE) (Layer 2 Protocol) (High-Speed data transfer)**
      - A lightweight encapsulation protocol and lacks the reliable data transport of the TCP layer.
      - Does not incorporate TCP or even IP Protocols.
      - This means that FCoE is a layer 2 (non-routable) protocol just like FC.
      - FCoE is only for short-haul communication within a data center
      - Use the following guidelines to mitigate FCoE security concerns:
        - Use strong authentication on the FCoE switches to limit administrator access.
        - Use role-based access control (RBAC) to limit user access to the data.
        - Use FCoE network devices that have policy-based security services that can span multiple devices and operating systems.
        - Configure switches to snoop for and filter out unwanted DHCP requests on the network.
        - Use network devices that can verify host IP addresses (IP source guard).
    - **Internet Small Computer System Interface (iSCSI)**
      - Internet Protocol (IP)-based storage networking standard linking data storage facilities.
      - Facilitates data transfer over intranets and manage storage over a long distance
      - Enable location-independent data storage and retrieval.

- **Multi-Protocol Label Switching (MPLS)**
  - Is a wide area networking protocol that operates at both Layer 2 and 3 and does **label switching.**
  - **The first device does a routing lookup, just like before, but instead of finding a next-hop, it finds the final destination router. And it finds a predetermined path from "here" to that final router. The router applies a "label" based on this information.**
  - Future routers use the label to route the traffic without needing to perform any additional IP lookups. At the final destinat ion router, the label is removed, and the packet is delivered via normal IP routing.
  - Understand the placement of LER and LSR in a network. **(IMP EXAM POINT)**
    - **LER - MPLS process starts here**
      - operates at the **edge of an MPLS network** and acts as the entry and exit points for the network
    - **LSR - Performs label switching in the core network**
      - Router located in the **middle of an MPLS network**. It is responsible for switching the labels used to route packets
  - 32-bit MPLS header
  - Why use MPLS
    - Implement traffic Engineering
    - Implementing Multi-Service Network
    - Improving Network Resiliency with Fast Route
- Voice over IP (VOIP)
  - Voice over IP (VoIP) is the transmission of voice traffic over IP based networks instead of using traditional analog circuits
  - VoIP (Voice over Internet Protocol) uses packet-switched technology to transport Voice over IP.
  - **Packet switching can cause latency issues especially when Voice and video are to be transported over IP** .
  - **Protocols**
    - **Session Initiation Protocol (SIP)** designed to manage multimedia connections, provides integrity protection through MD5 hash functions.
    - Secure Real-Time Transport Protocol or SecureRTP (SRTP) is a security improvement over the Real-Time Transport Protocol (RTP) that is used in many VoIP communications. SRTP aims to minimize the risk of VoIP DoS through robust encryption and reliable authentication.
    - H.323 = its an group of protocol
      H.225.0 for call signalling;
      Q.931, a protocol borrowed from ISDN, also used for call signalling;
      H.245 for negotiating audio/video channel parameters;
      H.235 for security and authentication;
      RTP, the Real Time Protocol defined by IETF, used to transmit audio/video streams;
      H.450.x for additional services like call transfer, call diversion, etc.
  - Voice over Internet Protocol (VoIP) refers to transmission technologies that deliver voice communications over IP networks. **IP telephony** uses technologies that are similar to TCP/IP, so its vulnerabilities are also similar.
  - The voice system is vulnerable to application manipulation (such as toll fraud and blocking), unauthorized administrative acc ess, and poor implementation.
  - In terms of the network and media, it is **also vulnerable to denial-of-service attacks against the gateways and network resources**.
  - **Eavesdropping is also a concern** since data traffic is sent in cleartext unless it is encrypted.
  - Problems
    - Packet Loss Concealment - Technique used to mask the effect of packet loss in VoIP
    - Jitter - Network delays
    - Sequence - Errors
  - Signal Protocol This is a cryptographic protocol that provides end-to-end encryption for voice communications, videoconferencing, and text message services. The Signal Protocol is nonfederated and is a core element in the messaging app named Signal.
  - Securing VoIP communications often involves specific application of many common security concepts
    - Use strong passwords and two-factor authentication.
    - Record call logs and inspect for unusual activity.
    - Block international calling.
    - Outsource VoIP to a trusted SaaS.
    - Update VoIP equipment firmware.
    - Restrict physical access to VoIP-related networking equipment

- Wireless (LAN/WAN)
  - Bluetooth **(Wireless Personal Area Network IEEE 802.15) (IMP EXAM)**
    - Bluetooth wireless technology is an **open standard for short-range radio frequency communication** used primarily to establish wireless personal area networks (WPANs) and has been integrated into many types of business and consumer devices.
    - Bluetooth uses a low-power signal with a maximum range of 100 meters (330 feet), primarily used in industrial environments.
    - Bluetooth is standardized within the IEEE 802.15 Working Group for WPAN
    - Attacks related to Bluetooth
      - **Bluesnarfing** - allows hackers to connect with your Bluetooth devices without your knowledge and extract information from them

        - **Bluebugging** - is an attack that grants hackers remote control over the features and functions of a Bluetooth device.
        - **Bluejacking** - allows an attacker to transmit SMS-Like messages to your device.
    - Countermeasure
        - Keep up with patching and security update
        - Do not use in an insecure public setting

- Wireless Metropolitan Area Network (aka WiMax) **802.16**
    - Standards for broadband wireless networks
    - Can potentially deliver data rates or more than 30 megabits per second.
    - Providers offer average data rates of 6 Mbps and often deliver less
    - **IEEE 802.16 standard**

- Wi-Fi (Wireless LAN **IEEE 802.11x**)
    - Uses the IEEE 802.11 specification to create a wireless LAN that may be secure
    - Links two or more devices over a short distance using a wireless distribution
    - Wireless frequency -
        - DSSS (Direct Sequence Spread Spectrum)
            - Sends data in single frequency either 2.4 or 5
        - FHSS (Frequency-hopping spread spectrum)
            - Sends data in multiple frequencies
        - OFDM (Orthogonal frequency-division multiplexing)
            - Signals are perpendicular
        - IEEE Standards

Standards	Frequency	Max Data Rate
802.11	2.4 GHz	2 Mbps
802.11a	5 GHz	54 Mbps
802.11b	2.4 GHz	11 Mbps
802.11g	2.4 GHz	54 Mbps
802.11n	2.4&5 GHz	600 Mbps
802.11 ac	2.4&5 GHz	6.93 Gbps

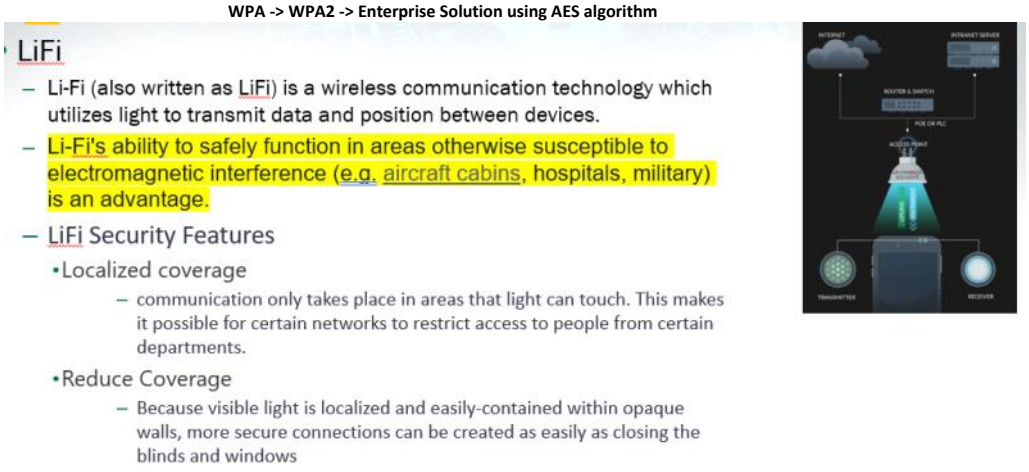
- There are two modes in wireless
    - Ad Hoc (connect using SSID)
    - Infrastructure (AP, connected to Ethernet, connected to switch)
- Wireless Security Standards
    - Shared Security Key -- Least Secure
    - WEP
    - WPA
    - WPA2 -- Most Secure

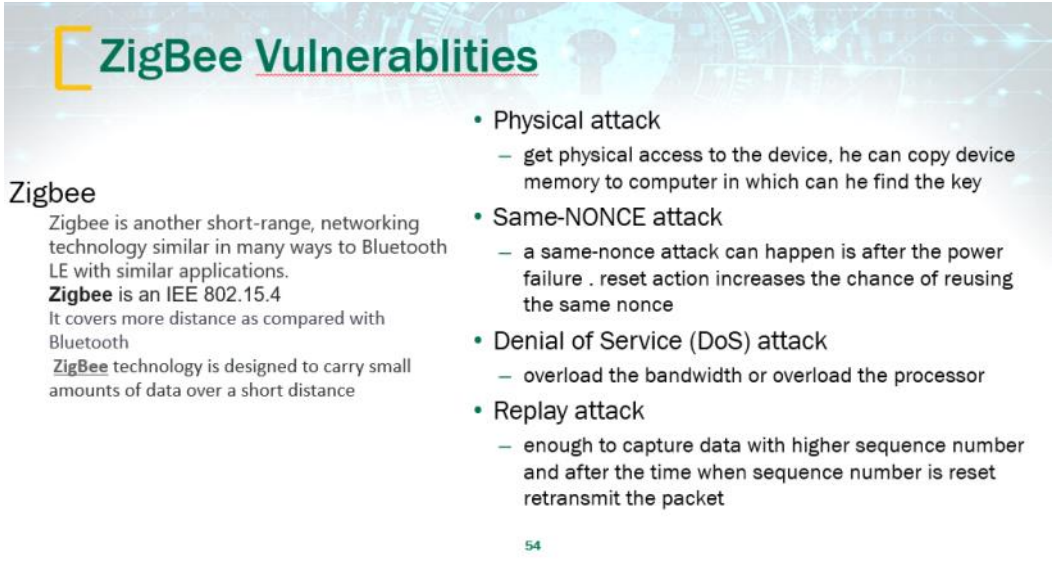
- WEP
    - WEP was introduced as a privacy component of the original IEEE 802.11 Standard
    - **WEP Uses the Stream cipher RC4 for Confidentiality**
    - **CRC-32** Checksum for Integrity.
    - Standard 64-Bit WEP uses a 40-bit key (Known as WEP-40), 24 Bit IV, every 5000 interactions the IV is repeated
    - Key & IV Length is small vulnerable to Brute Forces attacks.
    - Biggest concern: Privacy
- WPA
    - To overcome WEP, Change the key size to 128 bit (80-bit data & 48 bit IV) with MIC
    - Interim solution until the release of 802.11i
    - WPA introduce to improve Authentication & Encryption.
    - 64-bit Message Integrity Check (MIC) is introduced Replaces weak CRC
    - Still uses **RC4 stream Cipher for Encryption/Confidentiality**
    - Introduces the **TKIP (Temporal Key Integrity Protocol)**
    - Replaces WEP short key with the 256 bits per-packet key
    - **No need to change hardware**
- WPA2
    - Indicates full compliance with 802.11i
    - Replaces TKIP with 256-bit CCMP (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol)
    - AES based block cipher encryption stronger than TKIP
    - **Required upgrade of Hardware**
        - WPA-Personal
            - Also called WPA-PSK for Pre-Shared Key
            - Designed for Home or SOHO- small office home office
            - All Station uses the same 256-bit key

    - WPA-Enterprise
        - Also called WPA-802.1x mode or just WPA2
        - same 256 bit key, with a RADIUS authentication server
        - No vulnerable to dictionary attack like WPA
        - Uses the Extensible Authentication Protocol (EAP)
- WPA 3
    - Wi-Fi Protected Access 3 (WPA3) was finalized in January 2018
    - WPA3-ENT uses 192-bit AES CCMP encryption, and WPA3-PER remains at 128-bit AES CCMP.
    - WPA3-PER replaces the preshared key authentication with Simultaneous Authentication of Equals (SAE).
    - Some 802.11ac/Wi-Fi 5 devices were the first to support or adopt WPA3.

- **NOTE**

WPA -> WPA2 -> PSK (Personal shared key) using RC4
WPA -> WPA2 -> Enterprise Solution using AES algorithm

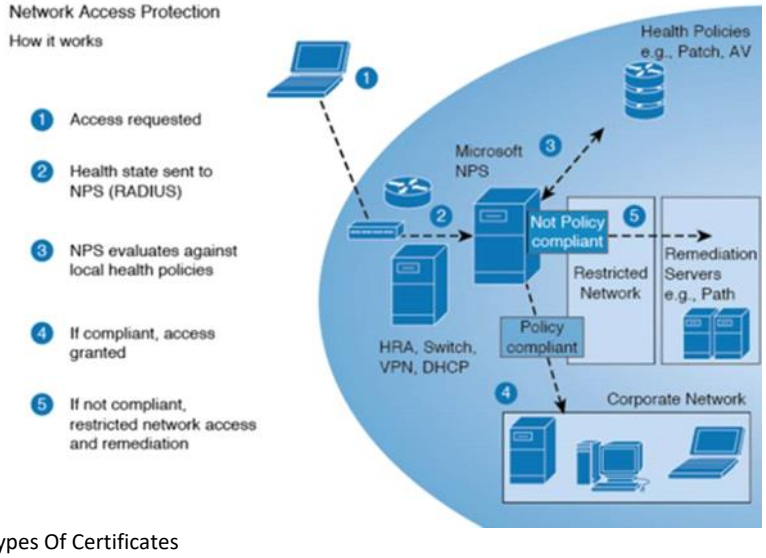
- 



- **EAP (Extensible Authentication Protocol)**
    - 802.1x authentication has been introduced in this protocol to improve authentication
    - Essentially it is a handoff system meant for wireless networks to leverage existing network infrastructure authentication services effectively.
    - **It's not an authentication mechanism but it is an authentication framework**.
    - Controls port access between devices, AP, and servers.
        - Uses Dynamic keys instead of static.
    - Radius performs Authentication, authorization, and accounting. WPA2 enterprise, the implementation is called 802.1x Between the Radius and AD it uses EAP.
    - EAP Facilities compatibility with new authentication technologies for existing wireless or Point-To-Point connection technologies
- LEAP (Lightweight Extensible Authentication Protocol)
    - Lightweight Extensible Authentication Protocol (LEAP) is a Cisco proprietary
    - alternative to TKIP for WPA, but it should not be used.
    - **Purely password based authentication framework**
    - LEAP served the purpose of addressing deficiencies in TKIP before the advent of 802.11i/ WPA2
- EAP-TLS
    - Carries out authentication using digital certification
    - EAP-TLS is the most secure (and costly) form of EAP because it requires both server and client-side certification

- PEAP (Protected Extensible Authentication Protocol)
    - PEAP (Protected EAP), developed by Cisco Systems, Microsoft, and RSA Security, is similar to (and may be considered a competitor to) EAP-TLS,including not requiring client-side certificates
- When implementing wireless security, use these recommendations:
    - When possible, use a RADIUS server for wireless authentication.
    - If you must use a pre-shared key, make the password complex and change it regularly.
    - If necessary, enter the MAC addresses of all devices that are permitted to connect to the wireless network into the access point Attacks
- Wireless Defense
    - Disable WEP
    - Change default SSID and disable "Broadcast SSID"
    - Implement another layer of authentication
    - Logically put the AP in DMZ
    - Implement VPN for Wireless stations to use
    - Configure ACL or firewall to only allow known MAC
    - Assign static IPs to stations and disable DHCP
    - Decrease power on AP and make use of WAP2
    - Carry Out penetration tests on the WAN.
    - Select WPA2 (even WPA2 personal) over WEP or WPA.
- Wireless Attacks
    - Wireless is prone to sniffing & eavesdropping. Different security standards in place. Over wireless, the data must be encrypted.
        - **Signal Jamming -** It is the malicious activity of overwhelming a WAP to the extent that legitimate traffic can no longer be processed. Even though this is illegal in most places, there are inexpensive jamming products, like a TV jammer, available for sale online.
        - **Wardriving:** Wardriving, in contrast, is when someone, usually in a moving vehicle, actively searches for Wi-Fi wireless networks using wireless network scanning.

- **Network Access Control (NAC)**
    - NAC as an approach for network security control implements several technologies to limit and meter access to private environments.
    - There are several basic goals for the use of NAC:
        - Mitigation of non-zero-day attacks
        - Authorization, authentication, and accounting of network connections
        - Encryption of traffic to the wireless and wired network using protocols for 802.1X such as EAP-TLS, EAP-PEAP or EAP-MSCHAP
        - Role-based controls of user, device, application, or security posture post authentication
        - Enforcement of network policy to prevent endpoints from access to the network if they lack up-to-date security patches or host intrusion prevention software
        - Ability to control access to the network based on device type and user roles
        - Identity and access management based on authenticated user identities instead of just blocking IP addresses
    - NAC options include using a host/system agent (agent-based) or performing overall network monitoring and assessment (agentless).
        - A typical operation of an agent-based NAC system would be to install a NAC monitoring agent on each managed system. The NAC agent retrieves a configuration file on a regular basis, possibly daily or upon network connection, to check the current configuration baseline requirements against the local system.
        - If the system is not compliant, it can be quarantined into a remediation subnet where it can communicate only with the NAC server. The NAC agent can download and apply updates and configuration files to bring the system into compliance. Once compliance is achieved, the NAC agent returns the system to the normal production network.
        - An agentless or network monitoring and assessment NAC solution performs port scans, service queries, and vulnerability scans against networked systems from the NAC server to determine whether devices are authorized and baseline compliant. An agentless system requires an administrator to manually resolve any discovered issues.
        - Other issues around NAC include out-of-band versus in-band monitoring, as well as resolving any remediation, quarantine, or captive portal strategies. You should evaluate these and other NAC concerns before implementation



- Types Of Certificates
    - Secure Multipurpose Internet Mail Extension (S/MIME)
        - S/MIME (Secure/Multipurpose Internet Mail Extensions) is a widely accepted method (or more precisely, a protocol) for sending digitally

signed and encrypted messages.
- S/MIME allows you to encrypt emails and digitally sign them.
- When you use S/MIME with an email message, it helps the people who receive that message to be certain that what they see in their inbox is the exact message that started with the sender.
- It will also help people who receive messages to be certain that the message came from the specific sender and not from someone pretending to be the sender.
- Application Layer Protocol
- Standard for encrypting and digital signing of Email
- Protects against forgery
- S/MIME provides for cryptographic security services such as authentication, message integrity, and non-repudiation of origin (using digital signatures). It also helps enhance privacy and data security (using encryption) for electronic messaging Object Signing
- S/MIME provides confidentiality through encryption algorithms, integrity through hashing algorithms, authentication through the use of X.509 public key certificates, and nonrepudiation through

- SSL
  - SSL is a set of rules governing server authentication, client authentication, and encrypted communication between server and client.
  - As part of the initial handshake process, the server presents its certificate to the client to authenticate the server's identity
  - The authentication process uses Public key encryption and digital signatures to confirm that the server is the server it claims to be.
  - Once the server is authenticated, the client and server use symmetric encryption techniques which is very fast to encrypt all the information that they want to exchange for the remainder of the session.
  - Client SSL Used to identify clients to Servers via SSL
  - Server SSL Used to identify Servers to Client via SSL

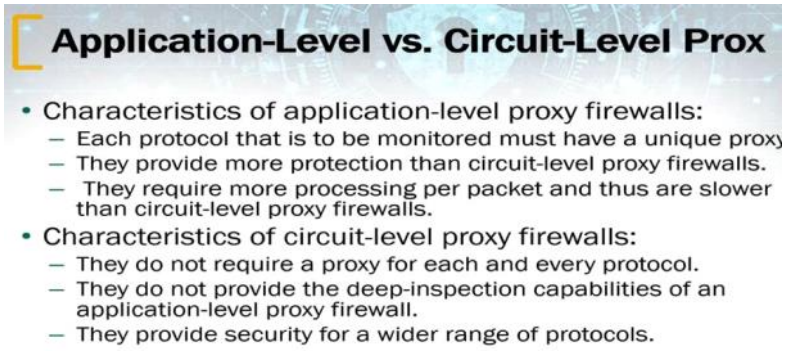
- **Design & Establish secure communication protocols**
  - Guidelines for Implementing Network Architecture Security
    - Understand the layers of the OSI and TCP/IP models and how your network technologies fit in those layers.
    - Pay attention to the vulnerabilities of each networking protocol that your organization implements.
    - Understand the vulnerabilities associated with multi-layer protocols, especially when it comes to SCADA systems.
    - If you implement FCoE, be aware of the threat of eavesdropping and denial of services attacks since Fiber-Channel and TCP/IP are sharing a network.
    - If you implement iSCSI, be aware that it is not encrypted by default.
    - Ensure that any MPLS implementations provide for proper load balancing to defend against DoS threats.
    - Incorporate VoIP in your network in a way that reduces packet loss, jittering, and other issues that could affect availability.
    - Use WPA2 to encrypt your Wi-Fi network, and always secure it with a strong password.
    - Implement network encryption protocols where possible to provide confidentiality, integrity, and authentication of communications in your network.

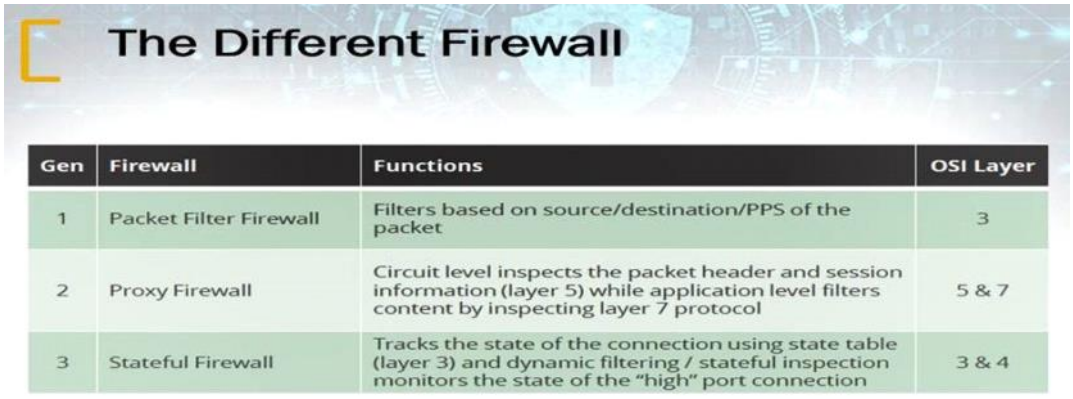
- **Secure Network Components**
  - **Firewall**
    - Firewalls filter traffic based on a ruleset.
    - Each rule instructs the firewall to block or forward a packet based on one or more conditions. For each incoming packet, the firewall will look through its rule set for a rule whose conditions apply to that packet and block or forward the packet as specified in that rule.
    - Types of Firewall
      - **Stateless Firewall (1st Gen packet filters)**
        - Controls traffic on source/destination and protocol
        - Also known as screening router or stateless inspection
        - Very basic in terms of protection operate at Layer 3 only
        - Can't inspect the content and discard attacks
        - Return traffic must be allowed explicitly
        - 2nd Gen Proxies
      - **2nd Generation Firewall**
        - Mediates communications between untrusted end-points
        - Internal Perspective - A proxy may forward traffic on behalf of an internal client.
        - **Hides the trusted internal clients**
        - **Application Level Proxy**
          - **Operates at application level layer (Level 7)**.
          - Relays traffic between a trusted end-point running a specific application to an untrusted endpoint.
          - Understands the inner working of the protocols.
          - Could be used to Decrypt and Encrypt SSL protocol.
          - They require more processing power per packet and are slower than the circuit level
          - They provide more protection and hence are slow.
          - Can have logging, auditing, and access control feature
          - Operating at this layer requires each packet to be completely opened and closed, making this firewall the most impactful on performance

      - **Circuit level Proxy**
        - **Works on a session-level layer (Level 5)**

        - Creates a conduit through which a trusted client can communicate with an Untrusted Host.
        - Can act as a VPN between client and Server
        - Inspects the packet header and session information to determine access permission
        - A SOCKS firewall works at the Session layer (Layer 5). not do deep packet inspection

- **Stateful Firewall (3rd Gen Stateful Firewall)**
    - Intercept packets at the network layer
    - Stateful inspection inspects packet in the context of the session
    - Monitor the state of the session - initiated, established, and terminated.
    - Can track connectionless protocol such as UDP
    - Fast and Efficient - No need to read the entire rule base.
    - Operates at Layer 3 and 4
- **Next-Gen Firewall**
    - Very fast and supports built-in IPS, able to connect to external services such as AD
    - Operates at multiple Layers i.e. L3 - L7
    - Unified Threat Management (UTM)
        - DoS protection , QoS ,VPN ,Stateful Firewall ,Deep ,Application Inspection , URL Filtering
        - Gateway Antivirus, IPS, Spyware Protection, Spam protection



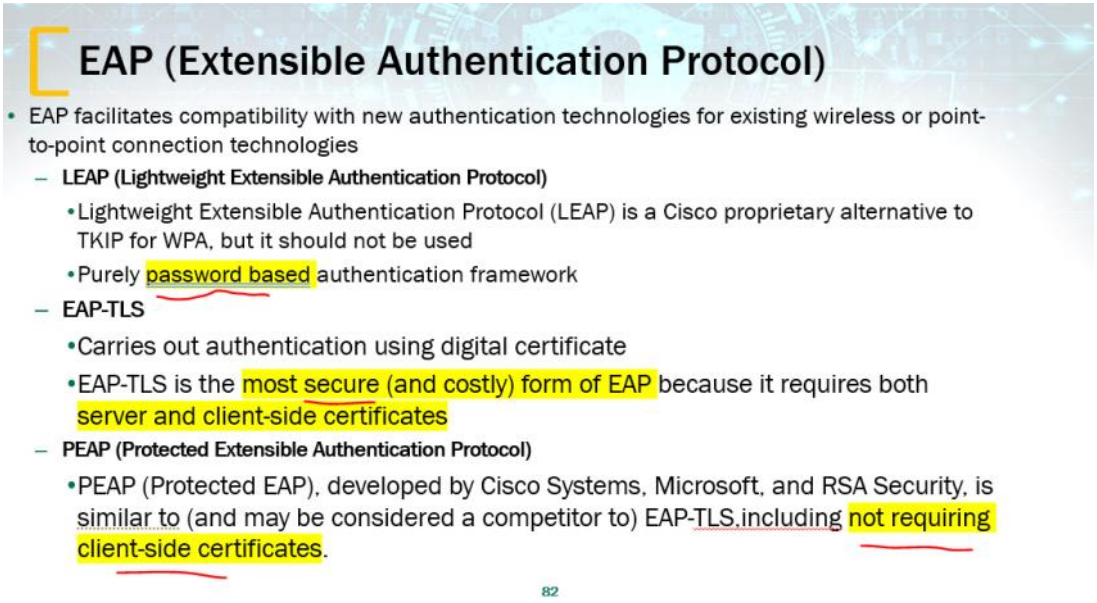


- **Recommendations when implementing Firewall**
    - Take the time to learn and implement the capabilities and limitations of your particular firewall product. While many administrators spend a great deal of time configuring the firewall, many other administrators leave firewalls in a default configuration, which might not be optimal.

    - Recognize that your network has many other possible points of entry besides the firewall. These include wireless access points, VPN servers, dial-up modems, and even "sneakernet" (users physically transporting data on removable media, plugging devices into the network behind the firewall). Use as much care securing these alternate points of entry as you would your firewall It is critical to hardening all Internet-facing devices
- **Network Address Translation (NAT)**
    - Primary objective of NAT is to hide internal networks from external ones.
    - **NAT by default won't with IPSEC AH mode, works with IPSEC ESP mode**
    - NAT and PAT - Routers and firewalls can change the source address of each packet to a different address, Port address translation allows the firewall to keep track of multiple sessions that are using PAT.
- **Type of NAT**
    - Static NAT (One to One)
    - Dynamic NAT (Many to Many)
    - PAT (One to Many)
- **Endpoint Security**
    - Workstations
        - Updated anti-virus and anti-malware software

        - Configured and operational host-based firewall
        - Hardened and Patched
    - Mobile Devices
        - Encryption for the whole device
        - MDM and remote management capabilities
        - User policies
- **Honeypots and Honeynets**
    - Honeypots are decoy systems used to attract and examine attacker activity and techniques.
        - High-interaction honeypots are “live” systems.
        - Low-interaction honeypots emulate the production environments.
    - Honeynets are multiple linked honeypots that simulate a network environment.

- Voice
    - **PSTN**
        - POTS - Circuit-switched network that was originally designed for analog voice communication.
        - PBX Internal phone system switch and attached to a telecom trunk.
            - Typically used in business
    - Attacks
        - **War Dialing**
            - Using automated dialing, the attacker dial an active range phone number to identify a modem
            - If the host to which the modem was attached had a weak password, the attacker could easily gain access to a network.
            - Countermeasure is to protect with a strong authentication password.
        - **War Driving** - Penetrate Open Wi-Fi
- Peer-to-Peer (P2P) Applications
    - Opens an uncontrolled channel in a network boundary, normally through tunneling.
    - Provides a way for dangerous contents such as
        - Botnets
        - Spyware applications
        - Viruses
- Protocols
    - Secure Communication Protocol
        - Protocol that provides security services for application-specific communication channels
        - IPSec, Kerberos, SSH, S-RPC, SSL/TLS, Authentication, Protocols
- Authentication Protocols **(EXAM IMP)**
    - Password Authentication Protocol (PAP)
        - Clear text exchange of username and password data
        - All communications are transmitted in clear text with no encryption.
        - PAP is a one-way authentication between the router and the host.
        - **Least Secure PAP**
    - Challenge Handshake Authentication Protocol (CHAP)
        - Enhanced security compared with PAP. It uses a two-way encrypted authentication method.
        - **CHAP Encrypts Username & Passwords.**
        - It also periodically authenticates the remote system.
        - The advantage of using CHAP Over PAP is the additional security provided by the shared secret used during the challenge & response: A sniffer that views the entire challenge/response process will not be able to determine the shared secret.
        - EXAM TIP MS-CHAP is Microsoft’s version of CHAP and provides mutual authentication functionality.
    - Extensible Authentication Protocol (EAP)
        - EAP allows customized authentication security solutions such as supporting **smart cards, tokens, and biometrics.**
        - **More Secure than CHAP**



- **Dial-up Protocol (EXAM IMP)**
  - Point-to-Point (PPP) (Layer 2)
    - PPP is widely supported and is the transport protocol of choice for dial-up internet connection and is widely supported.
    - PPP is protected using CHAP and PAP
    - Three-Component of PPP
      - Encapsulating multiprotocol diagram
      - LCP for establishing, configuring, and testing the data-link connection
      - NCPs for establishing and configuring different network-layer protocols

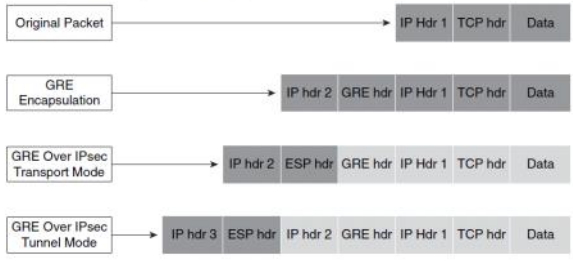
  - **Serial Line Internet Protocol (SLIP)**
    - Replacing PPP with SLIP, SLIP does not provide error detection and error correction.
    - It was used over low-speed serial interface
    - Used over Slow Serial interface
- **Virtual Private Network (VPN)**
  - The most common security definition is an encrypted tunnel between two hosts.
  - A tunnel is the encapsulation of one protocol with another
  - VPN offers confidentiality, Virtual Private Network (VPN)
    - Encrypted tunnel between the communicating hosts. Remote users employ a VPN to access organization resources securely.
    - VPN uses CHAP and MSCHAP as authentication mechanisms
  - Virtual Private Network (VPN) Two types of connections
    - Point-To-Point Tunneling Protocol (PPTP) (GRE)
      - Generic Routing Encapsulation (GRE), data is sent over plain text
      - Microsoft implementations, the tunneled PPP traffic can be authenticated with PAP CHAP, MS-CHAP, or EAP-TLS
      - Doesn't support TACACS+ and RADIUS
      - **PPTP, a Microsoft protocol,** allows remote users to set up a PPP connection to a local ISP and then create a secure VPN to their destination.
      - PPP payload is encrypted using Microsoft Point to- Point Encryption (MPPE)
      - PPTP has been the de facto industry-standard tunneling protocol for years, but the new de facto standard for VPNs is IPSec.
      - PPTP is designed for client/server connectivity and establishes a single point-to-point connection between two computers.
      - Do not provide encryption or authentication -- use IPSec for that purpose.
      - Supports PPP and offers authentication by way of PAP, CHAP & EAP.
      - It encapsulates the PPP packets and creates a point-to-point tunnel connecting two separate systems.
    - L2F
      - CISCO Developed protocol.
      - It does not offer encryption
      - It was replaced by L2TP
    - L2TP(IPSec)
      - It lacks a built-in encryption scheme, but it typically relies on IPSec as its security.
      - L2TP also supports TACACS+ & RADIUS
      - IPSec is commonly used as a security mechanism for L2TP.
      - L2TP does offer authentication by way of PAP, CHAP & EAP.
    - One VPN solution is not necessarily better than the other; they just have their focused Purposes:
      - PPTP is used when a PPP connection needs to be extended through an IP-based network.
      - L2TP is used when a PPP connection needs to be extended through a non– IP-based network.
      - IPSec is used to protect IP-based traffic and is commonly used in gateway-to-gateway connections.

- TLS VPN is used when a specific application layer traffic type needs protection

- Split Tunnel vs. Full Tunnel
  - A split tunnel is a VPN configuration that allows a VPN-connected client system (i.e., remote node) to access both the organizational network over the VPN and the internet directly at the same time. The split tunnel thus simultaneously grants an open connection to the internet and to the organizational network.This is usually considered a security risk for the organizational network since, when a split-tunnel VPN is established, an open pathway exists from the internet through the client to the LAN.
  - A full tunnel is a VPN configuration in which all of the client's traffic is sent to the organizational network over the VPN link, and then any internet-destined traffic is routed out of the organizational network's proxy or firewall interface to the internet. A full tunnel ensures that all traffic is filtered and managed by the organizational network's security infrastructure

- **IPSec**
  - A Suite of protocols for communicating securely with IP
  - Provides a mechanism for authentication and encryption
  - Provides a framework of services such as encryption, authentication, and integration.
  - IPSec provides encapsulation and not encryption
  - IPsec - Provides Port level security, LAN-based security, packet filtering services, and Security over VPN solutions, It provides key agreement service.
  - IPSec/AH doesn't work with NAT, because NAT requires header modification. IPSec/ESP works with NAT.
  - Different modes of operations
    - Transport
      - IP Payload is protected = Exam point not secured
      - Used for end-end protection
      - Use IPSec transport mode when you want to create a secure end-to-end connection between nodes, such as a client and a server
    - Tunnel
      - **IP Payload and IP headers both are protected = Exam Point more secured**
      - Often used in site-site VPN's
      - Provides limited traffic flow confidentiality
      - It is used between firewall to firewall VPNs

Figure 1-8 *Tunnel and Transport Mode Example*



  - **IPSec Components (Protocols) (EXAM POINT)**
    - AH
      - Provides authentication, integrity, and nonrepudiation.
      - The primary purpose of the AH is to confirm the source of the packet. Also, it ensures the contents of both the header and th e payload have not changed. In short, the AH provides integrity.
      - The authentication header is used to prove the identity of the sender and ensure that the transmitter data has not been alter ed. This can cause a problem with NAT.
      - Used ICV (Integrity Check Value) to provide integrity
        - Integrity check is performed on the whole packet and not just on data.
        - This ensures that neither the data nor the header or trailers are altered, this caused problems with NAT.

  - **ESP**
    - **ESP offers Confidentiality, authentication, and Integrity checking just on the payload, so it is compatible with NAT.**
    - Provides encryption to protect the confidentiality of transmitted data, but it can also perform limited authentication. The E SP provides confidentiality and typically encrypts the payload but not the packet header. Following the IP header is the ESP header, whic h includes a sequence number. After the ESP header is the payload data and then the integrity check. Padding may be included if necessar y
  - **Key Management**
    - IKE (Diffie-Hellman)

- It allows two devices to exchange symmetric key for the use of encrypting AH & EAP
- There are two ways to exchange key
  - Use a Diffie-Hellman style negotiation
    - Used when we need to communicate between two Routers.
  - Use Public Key Certificates
    - Would be Used in end VPN Connections
    - More Secure
- SKIP (Simple Key-Management for Internet Protocol)
  - Hybrid Key Exchange protocol similar to SSL
  - SKIP uses the knowledge of its own secret key or private component and the destination public key.
  - It is similar to the SSL

- **For questions and more clarity refer IPsec Coffee Dose** Link

Exam Points

Question	Answer
Only the data is encrypted	Transport Mode
The entire packet is encrypted = most secured	Tunnel Mode
Authentication Header (AH):	Integrity , Authentication and Non-Repudiation
Encapsulation Security Payload	AH + Encryption
Ipsec work on which layer	Layer 3
If a connection is using IP, PPP, and L2TP, where does IPSec come into play?	IPSec provides the encryption, data integrity, and system-based authentication.
framework for security association creation and key exchange	ISKMP

- **L2TP Vs PPTP Vs IPsec**
  - L2TP can Tunnel through networks that incorporate many types of protocols such as X.25, ATM & Frame Relay
  - PPTP & IPsec can only work over IP-based Networks
  - For Dial, Up connectivity PPTP only work
  - Protocols @ VPN are – PPTP, L2TP & IPsec
  - Use L2TP when traffic needs to travel over different WAN technologies
- **PPTP Vs L2TP**
  - Only IP Based Vs. IP, Frame Relay, x.25 or ATM
  - No Header Compression Vs. Header Compression
  - No Tunnel Auth Vs. Tunnel Auth
  - Built-in PPP Encryption Vs. Use IPsec Encryption
    - **Circuit Switching Vs Packet Switching**

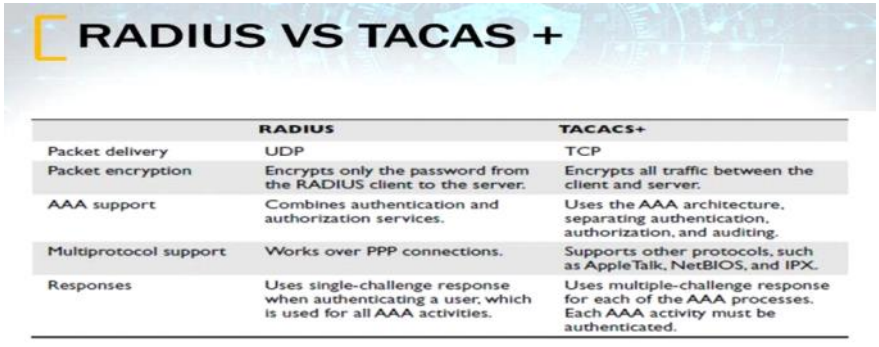
Feature	Circuit	Packet
Summary	Dedicated channel is created between 2 communicating parties. Once the connection is established, link remains the same (consistent connection). All data follows the same path.	Message is broken in small segments and each packet search its own way to destination
Technologies	PSTN, ISDN, DSL, T-carriers	X.25, Frame Relay, ATM, VOIP, MPLS, cable modems (Very high speed, shared bandwidth)

Protocol	Auth	Data Encryption	Protocols	Dial-Up	# Connection
PPTP	Yes	No	IP	Yes	Point to Point
L2F	Yes	No	IP	Yes	Point to Point
L2TP	Yes	No	Any	Yes	Point to Point
IPSec	Yes	Yes	IP	No	Multiple

- **Remote Authentication Dial-in User Services (RADIUS)**
  - Authentication protocol used in network environments

- **Vulnerable for Reply Attacks.**
- Provide Scalable, centralized authentication.
- Commonly used in the form of 802.1x (a combination of EAP & RADIUS)
- Lacks integrity protection
- User Identification is transmitted in clear text, Password is encrypted.
- UDP An authentication protocol used in a networked environment.
- RADIUS is the appropriate protocol when simplistic username/password authentication
- RADIUS is a standard and is described in RFC 2138 and RFC 2139
- RADIUS is an open protocol ✓ RADIUS only encrypts the user's password
- RADIUS allows companies to maintain user profiles in a central database.
- When a user dials in and is properly authenticated, then a pre-configured profile is assigned to him to control what resources he can and cannot access.
- The RADIUS client cannot authenticate or assign profiles, this is the RADIUS server's job.
- Centralized access control administration is very commonly done using the Remote Authentication Dial-In User Service (RADIUS) protocol

- **Terminal Access Controller Access Control System (TACACS+)**
  - Use TCP Protocol
  - TACACS+ does not have to implement transmission control. RADIUS, however, does have to detect and correct transmission errors like packet loss, timeout, etc. since it rides on UDP which is connectionless.
  - **Cisco Proprietary**
  - TACACS+ encrypts all of this information between the client and the server.
  - TACACS+ are client/server protocols
  - TACACS combines its authentication and authorization processes
  - XTACACS separates authentication, authorization, and accounting processes
  - TACACS+ is XTACACS with extended two-factor user authentication.
- **DIAMETER**
  - Diameter is a peer-based protocol
  - Up until the conception of Diameter, IETF had individual working groups who define how Voice over IP (VoIP), Fax over IP (FoIP), Mobile IP, and remote authentication protocols work
  - It requires customers to roll out and configure several different policy servers and increases the cost with each newly added service.
  - With Diameter, all of these services can be authenticated over the same authentication architecture



	RADIUS	TACACS+
Packet delivery	UDP	TCP
Packet encryption	Encrypts only the password from the RADIUS client to the server.	Encrypts all traffic between the client and server.
AAA support	Combines authentication and authorization services.	Uses the AAA architecture, separating authentication, authorization, and auditing.
Multiprotocol support	Works over PPP connections.	Supports other protocols, such as AppleTalk, NetBIOS, and IPX.
Responses	Uses single-challenge response when authenticating a user, which is used for all AAA activities.	Uses multiple-challenge response for each of the AAA processes. Each AAA activity must be authenticated.

Radius	TACACS+	Diameter
Uses the User Datagram Protocol (UDP)	Uses Transmission Control Protocol (TCP)	Uses TCP
Remote Authentication Dial-in User Service	Terminal Access Controller Access-Control System	Can authenticate wireless devices and smart phones
Used when an organization has more than one network access server	Successor of Radius	New and improved Radius
Many Internet service providers (ISPs) use RADIUS for authentication	TACACS+ encrypts all of the authentication information, not just the password as RADIUS does	Supports Internet Protocol Security (IPsec) and Transport Layer Security (TLS) for encryption
RADIUS provides AAA services between network access servers and a shared authentication server	Provides higher level of reliability for the packet transmissions	

- **Content Distribution Networks (CDN) (EXAM IMP)**
  - File & Media Streaming keyword Availability - CDN
  - **Goal of CDN - To serve content to end-users with high availability and high performance.**
  - The nature of the architecture model is to provide low latency, high performance, and high availability of content.
  - A large distributed system of servers deployed in multiple data centers across the internet.
  - Content is acquired as near to the requesting customer as possible, which results in lower latency and greater throughput
  - CDNs also reduce the vulnerability to DOS/DDOS attacks
  - Ex: Amazon Prime, Bit torrent, Primary objective of CDN is content availability, not security.

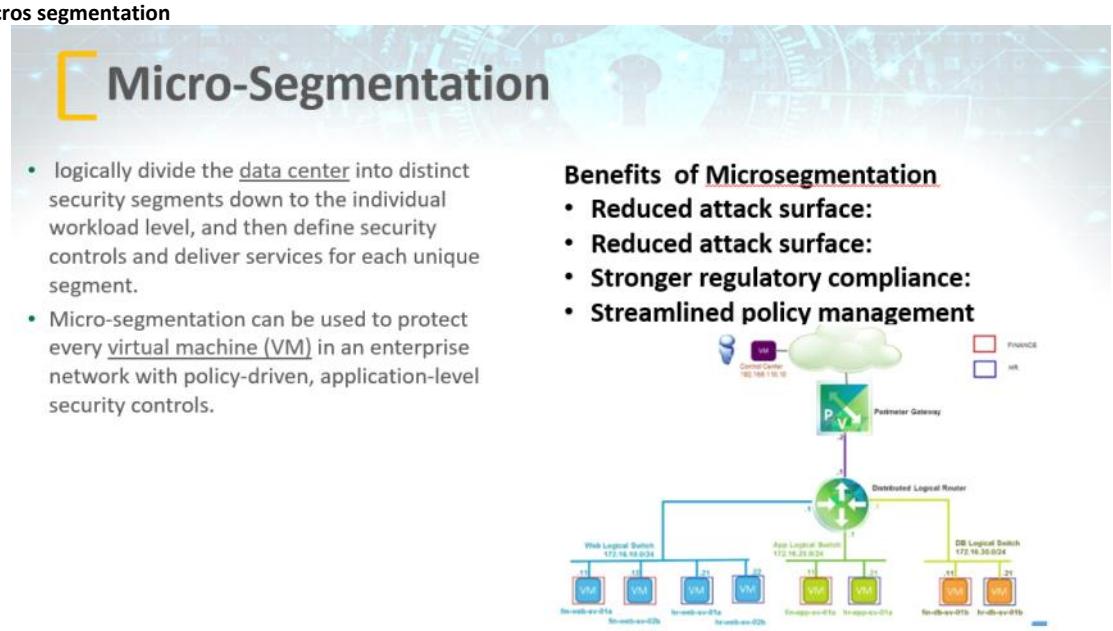
- Objective of CDN save latency.
- One of the biggest concern with CDN is Legal and regulatory concern of data sharing

- **SNMP**
  - Three Version - SNMPv3 latest, being most Secure
  - Designed to manage network infrastructure
  - SNMP consists of a Manager and a Client Allows the manager to "get" the value of the variables from the client.
  - A protocol to monitor the health and status of IP networking devices
  - Public Strings if its enable its an concern
  - Consists of an SNMP manager and an SNMP agent management information base (MIB)
  - The SNMP manager monitors the information sent back from all the SNMP agents
  - SNMP agents can be configured on the devices which require health monitoring (routers, firewalls, load balancers, servers, wireless access points)
- **Remote Access Services (RAS)**
  - Protocols that allow remote access and working capabilities
  - Telnet ,Rlogin ,RCP ,RSH
- **High Assurance Internet Protocol Encryptions (HAIPE)**
  - Used for highly secure communications
  - Uses Pre Placed Keys (PPK's) or Firefly Vectors (FFV's) to create VPN's
  - At the intersection of protected and unprotected networks place a HAIPE device.
- **Switches Networks**
  - Circuit Switched
    - Circuit-switched networks establish a dedicated circuit between endpoints.
    - PSTN ,ISDN ,DSL
  - **Packet Switched**
    - Data is divided into packets and transmitted on a shared network.
    - Each packet contains meta-information so that it can be independently routed on the network
    - X.25 ,Frame Relay , ATM ,MPLS
    - Asynchronous Transfer Mode (ATM)
      - Connection-Oriented protocol designed to transmit data, voice, and video over the same network.
      - Speed - 155 Mbps
      - Size of Cell - 54 Bytes
  - **Virtual Circuits**
    - Virtual circuits provide a connection between endpoints over high bandwidth, multiuser cable, or fiber that behaves as if the circuit were a dedicated physical circuit
    - Permanent Virtual Circuits (PVC)
      - the carrier configures the circuit's routes when the circuit is purchased.
    - Switched Virtual Circuits (SVC)
      - Are configured dynamically by the routers each time the circuit is used.
- **Virtual Local Area Network (VLANS)**
  - Vlans allows the creation of Software-Based LAN Segments
  - Devices that share the a VLAN communicate through switches without being routed to other sub-networks.
  - Two common attacks against the switch:
    - ARP Attack
      - ARP spoofing is where an attacker pretends to be another computer on a network by telling the network gateway to request for the victim's MAC address from his/her machine IP address.
      - The same process is repeated vice versa with the victim, making the victim see the attacker's IP address as the gateway addre ss ARP replies.
    - MAC Flooding Attack
      - MAC (Media Access Control) Flooding is a type of cyber-attack done in a network to compromise the security of the network switches. In this attack, the network is flooded with the fake MAC addresses.
      - The hacker uses this attack to steal sensitive data that is being transferred in the network. The attack is used for forcing the legitimate MAC table contents out of the switch and forcing the unicast flooding behavior for potentially sending sensitive information to portions of the network where it is not normally intended to go.

- **Software Defined Networking (SDN) - Network virtualization**
  - SDN enhances the benefits of data center virtualization, increasing resource flexibility and utilization and reducing infrastructure costs and overhead
  - SDN is the use of multiple virtualized network resources to create converged network.
    - EX: NSX (Network Flow virtualization) Entire network is designed using software.
  - The central management interface is used to create a network that utilize network resources in the virtual data center.
  - Shift of Capex to OPEX
  - SDN is that it is effectively network virtualization It allows data transmission paths, communication decision trees, and flow control to be virtualized in the SDN control layer rather than being handled on the hardware on a per device basis.
  - Three Layers of the SDN Architecture
    - Application Layers (Application Plan)

        - all the business applications that manage the underlying Control Plane are exposed with North Bound Interfaces.
    - Control Layers (Control Plan) (Exam Point)
        - Control of network functionality and programmability is directly made to devices at this layer.
        - OpenFlow was the original framework/protocol specified to interface with devices through South Bound Interfaces
        - **If that control layer is compromised everything is compromised**
    - Infrastructure Layer (Infrastructure Plan) (Router, Switches)
        - The network switches and routers are located at this plane associated with the infrastructure.
        - The process of forwarding data is accomplished at this plane
- Both cloud computing and virtualization can benefit from SDN. Both functions need
    - Better traffic management.
    - Scalability
    - Reliability of critical data delivery.
    - Increased bandwidth.
    - Faster provisioning of network services

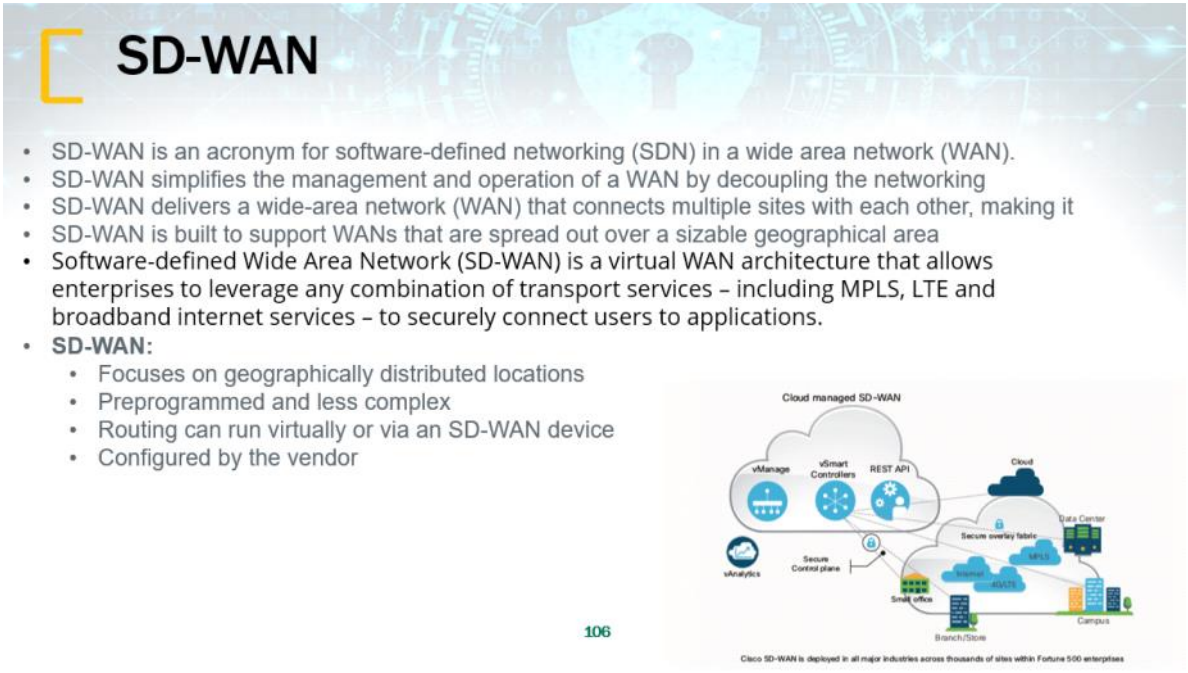
- **Micros segmentation**



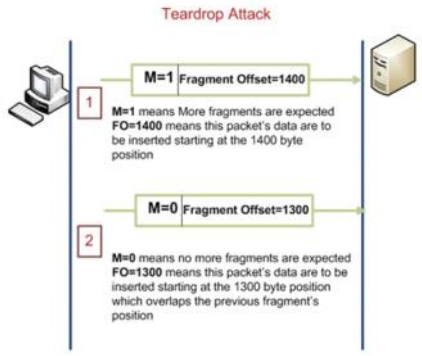
Also, micro-segmentation can be used to protect every virtual machine (VM) in an enterprise network with policy-driven, application-level security controls. Because security policies are applied to separate workloads, micro -segmentation software can significantly bolster a company's resistance to attack

- Microsegmentation benefit
    - ☐ Boosting Performance Network
    - ☐ Reducing Communication Problems
    - ☐ Providing Security

- **SDWAN**

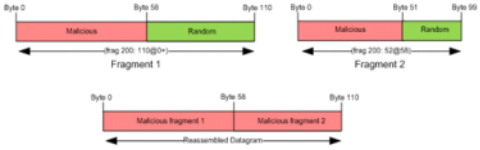


- **Prevent or Mitigate Network Attacks**
  - Confidentiality
    - Attacks on confidentiality are by far the most prevalent today because information can be sold or exploited for profit in a huge variety of (Mostly Criminal) ways
  - Availability
    - Availability is the property of a network service related to its uptime, Speed, and latency.
  - Integrity
    - A network needs to support and protect the integrity of its traffic.
  - Open Mail Relay Servers
    - An SMTP service that allows inbound SMTP connections for domains it does not serve.
    - A Principal tool for the distribution of spam, as they allow an attacker to hide their identity
  - **Spam**
    - By far the most common way of suppressing spam is email filtering on an email gateway
    - Filtering based on simple keywords can be the first step. Most sophisticated filters may be based upon statistical analysis or email traffic patterns.
    - SPIT - Spam over Internet Telephony
    - SPIM - Spam over Instant Messenger
  - **Port Scanning**
    - Tried to identify open ports, an attacker to identify any ports open on the server the attacks SYN packets on all the hosts, these ports restricted on the firewall / Patch the system as a second option and disable the service.
    - Port Scanning is an act of probing for TCP services on a machine
    - It is performed by establishing the initial handshake for a connection
    - Port scanning also can be used for fingerprinting an operating system by evaluating its response characteristics
    - Protection from port scanning includes restriction of network connections.
    - Three types of Port scanning (Tool is NMAP)
      - FIN scanning (Sending FIN Packet to know the open ports)
      - NULL scanning (No Flags sent to machine)
      - XMAS scanning (sending FIN/URG and PSH)
    - Disable ICMP echo request on Network
  - Teardrop
    - A teardrop attack is a denial-of-service (DoS) attack that involves sending fragmented packets to a target machine. Since the machine receiving such packets cannot reassemble them due to a bug in TCP/IP fragmentation reassembly, the packets overlap one another, crashing the target network device.
    - Teardrop is part of Fragmentation attack
    - **Fragmentation/Teardrop happens on Network Layers**
    - Alters the fragment offset field

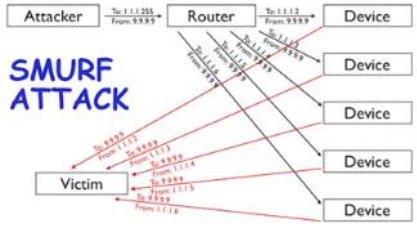
- 

    - The length of the packet indicated is not the true length
    - Results in packets being overlapped
    - Causes a system crash
    - Countermeasure

      Host OS and router have patching that inspects discrepancy in fragment offset and drops malformed fragment packets
- **Overlapping Fragment Attack**
    - The IP fragment overlapped exploit occurs when two fragments contained within the same IP packet have offsets that indicate that they overlap each other in positioning within the packet
    - Used to Subvert packet filters that only inspect the first fragment of a fragmented packet.
    - The technique involves sending a harmless first fragment that satisfies the packet filter
    - A solution to this is for TCP/IP stacks to not allow fragments to overwrite each other.



- **Smurf & Fraggle Attack**
    - Attack happens on Layer 3 and the Protocol used is ICMP
    - The **Smurf attack** is a distributed denial-of-service attack in which large numbers of Internet Control Message Protocol (ICMP) packets with the intended victim's spoofed source IP are broadcast to a computer network using an IP broadcast address.
    - Spoof Target IP as a Source IP and destination Broadcast, send ICMP request 900/1500 hosts, when they receive the ICMP, the reply back to the Target IP (service not available and interrupted)
    - **Fraggle Attack** is a denial-of-service (DoS) attack that involves sending a large amount of spoofed UDP traffic to a router's broadcast address within a network.
    - It is very similar to a Smurf Attack, which uses spoofed ICMP traffic rather than **UDP No 7** traffic to achieve the same goal.
    - Disable ICMP echo request on the network
    - **Fraggle attack Countermeasure: Do not allow a router to forward a request to network direct broadcast address**



- Denial-Of-Attack **(EXAM IMP)**
    - **Attack happens on Layer 7**
    - A denial-of-service attack (DoS attack) is a cyber-attack where the perpetrator seeks to make a machine or network resource unavailable to its intended users by temporarily or indefinitely disrupting services of a host connected to the Internet.
    - Denial of service is typically accomplished by flooding the targeted machine or resource with superfluous requests in an attempt to overload systems and prevent some or all legitimate requests from being fulfilled.
    - A DoS attack is analogous to a group of people crowding the entry door or gate to a shop or business, and not letting legitimate parties enter into the shop or business, disrupting normal operations.
    - Countermeasures
        - **Multiple layers of firewall, Careful filtering, Redundant network connections, load balance, Reserved Bandwidth, Blocking traffic from an attacker on an upstream router.**
- SYN Flood attack
    - **Attack happens on Layer 4**
    - A SYN flood is a form of denial-of-service attack in which an attacker sends a succession of SYN requests to a target's system in an attempt to consume enough server resources to make the system unresponsive to legitimate traffic.
    - Attacker SPOOF IP that doesn't exist, target tried to ack syn/ack, SYN Packet will be in memory in 70 sec. Attacker sends multiple SYN to the IPS doesn't exist and sending all the SYN, memory-filled with fake SYN requests. The legal SYN Packets are refused due to overflow.
    - **DOS Attack using the initial handshake in a TCP Connection**

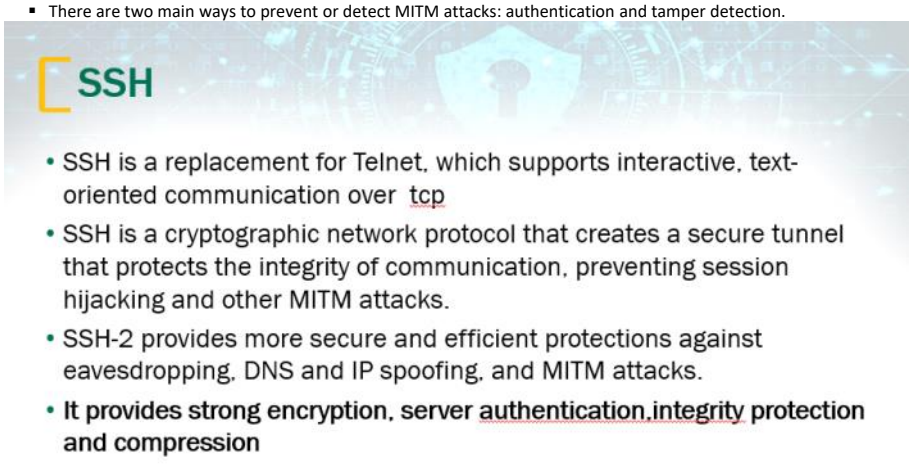
- Many new connections from faked, random IP addresses are opened in short order, overloading the target's connection table.
- **Counter Measures**
  - **Tuning of OS parameters such as size of the backlog table according to vendor specifications.**

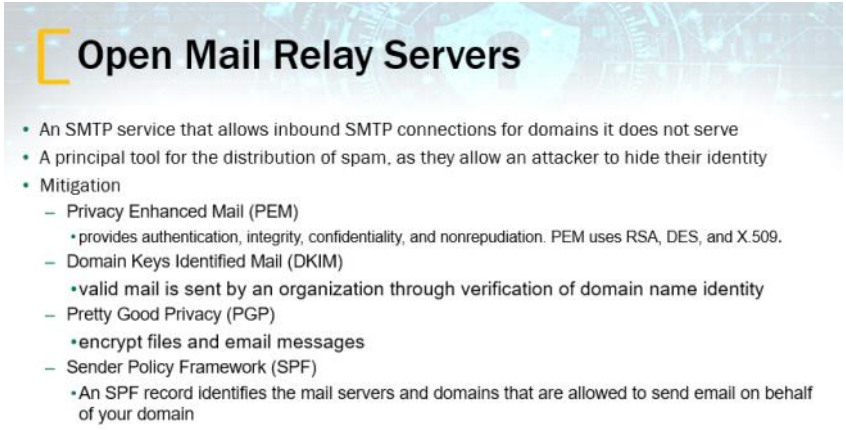
- Ping of death
  - Sending a ping packet that violates the Maximum Transmission Unit (MTU) size of 65,536 bytes, causing a system crash
- Ping flooding
  - Overwhelming a system with a multitude of pings
- Buffer overflow
  - An attack that overwhelms a specific type of memory on a system— the buffers. Robust input validation in applications prevents this attack.
- Ping sweep
  - Is used to discover live hosts on the network by pinging a series of IP addresses
- Non-Blind Spoofing
  - takes place when the attacker is on the same subnet as the victim and is only monitoring data, and not intercepting the data.
- Blind Spoofing
  - **Attack happens on Layer 3**
  - More sophisticated attack, several packets are sent to the target machine to sample sequence numbers and to eventually detect the correct sequence. Primary objective is to identify and hijack the session.
  - Also called a TCP Sequence attack.
- LAND Attack
  - Source & Destination same, creating loop
  - A land attack is accomplished by sending the spoofed TCP SYN packets with the victims own IP Address so that the victims machine replies to itself causing a DoS.
- Replay Attack
  - **A replay or a playback attack reused legitimate communications in an attempt to gain unauthorized access**
- VM escaping
  - It occurs when software within a guest OS can breach the isolation protection provided by the hypervisor to violate the container of other guest OSs or to infiltrate a host OS. Several escaping vulnerabilities have been discovered in recent times.
  - VM escaping can be a serious problem, but steps can be implemented to minimize the risk
- ARP Poisoning
  - ARP table poisoning, also referred to as ARP cache poisoning, is the process of altering a system's ARP table so that it contains incorrect IP to MAC address mappings. This allows requests to be sent to a different device instead of the one it is intended for. It is an excellent way to fool systems into thinking that a certain device has a certain address so that information can be sent to and captured on an attacker's computer.
- DNS
  - DNS resource record is the mapping of a domain name to an IP address
  - DNS zone is a group of resource records (e.g. admin, engineers, etc.)
  - Zone transfer is the copying DNS zones to other DNS servers
  - An authoritative server is the DNS server containing the original zone information
  - Recursive lookup/query sent to 1 or more DNS servers to find the correct resource record
  - Non-recursive lookup/query goes to a specific DNS server only
  - Split DNS: separate DNS servers for different lookups
  - DNS Cache Poisoning attack sends a victim to a spoofed webpage Also called DNS Spoofing.
  - DNSSEC Preventing forged DNS records by requiring digital signatures
  - DNS architecture places servers in strategic places, using zones and filtering communications
  - DNS HIJACKING
    - DNS Hijacking attack uses a hijacked DNS server to send a victim to a spoofed webpage
    - DNS Hijacking is an attack that forces the victim to use a Malicious DNS server instead of the legitimate one.
      - Host-Based
        - Modify the DNS Server address (or) local hosts file
      - Network Base
        - Poisoning the ARP table
      - Server Base
        - Poisoning the DNS cache

  - DNS poisoning attacks alter a victim's DNS table with incorrect information
  - DNS Spoofing
    - Sending false replies to a requesting system
    - Hyperlink Spoofing ---- Same as DNS spoofing
  - **DNS Pharming**
    - Malicious redirection of a valid website's URL or IP address to a false website that hosts a false version of the original web site
    - Pharming can be conducted either by changing the host's file on a victim's computer or by the exploitation of a vulnerability in DNS server software. DNS servers are computers responsible for resolving Internet names into their real IP addresses. Compromised DNS servers are sometimes referred to as "poisoned".
  - Domain Hijacking/Domain Theft
    - It is the action of changing the registration of a Domain name with the authorization of the valid owner
  - DNS resource record is the mapping of a domain name to an IP address
    - DNS zone is a group of resource records (e.g. admin, engineers, etc.)

- Zone transfer is the copying DNS zones to other DNS servers
- Authoritative server is the DNS server containing the original zone information
- Recursive lookup/query sent to 1 or more DNS servers to find the correct resource record
- Non-recursive lookup/query goes to a specific DNS server only
- Split DNS: separate DNS servers for different lookups o DNS Cache Poisoning attack sends a victim to a spoofed webpage
- Also called DNS Spoofing, Pharming, et
- DNS Hijacking attack uses a hijacked DNS server to send a victim to a spoofed webpage
- DNSSEC Preventing forged DNS records by requiring digital signatures
- DNS architecture places servers in strategic places, using zones and filtering communications

- **Man-in-the-Middle Attacks**
  - **In a communication where sender and receiver believe they are connected, a MITM attack can be hard to detect and presents a significant threat to unprotected communications. In a MITM attack, the attacker intercepts the signal and secretly relays (and possibly alters) the communication before stopping the transmission or allowing the message to reach the intended recipient**
  - **In a MITM attack, the attacker intercepts the signal and secretly relays (and possibly alters) the communication before stopping the transmission or allowing the messageto reach the intended recipient**
    - Eavesdropping is a specific type of MITM attack
    - Another type of MITM attack is impersonation
  - There are two main ways to prevent or detect MITM attacks: authentication and tamper detection.





- DKIM (DomainKeys Identified Mail) is a protocol that allows an organization to take responsibility for transmitting a message by signing it in a way that mailbox providers can verify. DKIM record verification is made possible through cryptographic authentication. Implementing email authentication technology like DKIM is one of the best ways to protect your employees and customers from targeted email attacks
- An SPF record identifies the mail servers and domains that are allowed to send email on behalf of your domain. Receiving servers check your SPF record to verify that incoming messages that appear to be from your organization are sent from servers allowed by you.
  - To protect against spam and email spoofing, an organization can also configure their SMTP servers for Sender Policy Framework. SPF operates by checking that inbound messages originate from a host authorized to send messages by the owners of the SMTP origin domain. For example, if you receive a message from mark.nugget@abccorps.com, then SPF checks with the administrators of smtp.abccorps.com that mark.nugget is authorized to send messages through their system before the inbound message is accepted and sent into your recipient's inbox
- Domain Message Authentication Reporting and Conformance
  - is a DNS-based email authentication system. It is intended to protect against business email compromise (BEC), phishing, and other email scams. Email servers can verify if a received message is valid by following the DNS-based instructions; if invalid, the email can be discarded, quarantined, or delivered anyway